AWESOME CYBER SECURITY HEAVEN — REALM DOSSIER · 2026 EDITION

# The Foundry

## DevSecOps, Cloud & Container Security Tools

| 62 | 281,001 | 78% | 36 |
|---|---|---|---|
| FREE TOOLS | COMMUNITY STARS | ON GITHUB ACTIVE | ACTIVE IN 2026 |

*62 tools · Part of Awesome Cyber Security Heaven — 1435 curated free tools across 14 realms · Data verified 2026-11-06 (re-verified monthly)*

## CURATOR'S NOTES

The pipeline guardians — SAST, dependency scanning, IaC misconfig audits, container hardening. This realm moves fastest of all: CI/CD attack research regularly rewrites the ground rules here.

## MAINTENANCE SNAPSHOT (2026-11-06)

- **Active in the last 30 days:** 29 of 38 tracked GitHub repos (76%)
- **Quiet classics (no push in 12+ months, still listed):** ScoutSuite, ProgPilot
- **Earliest entries:** cppcheck (2009), Brakeman (2010), Dependency-Track (2013)

## FLAGSHIP PICKS — THE HEAVYWEIGHTS

| TOOL | ★ STARS | CREATED | LAST PUSH | WHAT IT DOES |
|---|---|---|---|---|
| Trivy | 38.9k | 2019 | 2026-10-30 ✅ | Find vulnerabilities, misconfigurations, secrets, SBOM in containers, Kubernetes, code repositories, clouds an… |
| Semgrep | 17.4k | 2019 | 2026-10-30 ✅ | Lightweight static analysis for many languages. Find bug variants with patterns that look like source code. |
| Prowler | 15.1k | 2016 | 2026-11-01 ✅ | This repo hosts Prowler OSS (CLI and Local Server). Prowler is the world's most widely used open-source cloud… |
| Grype | 13.2k | 2020 | 2026-10-30 ✅ | A vulnerability scanner for container images and filesystems |
| Kubescape | 11.8k | 2021 | 2026-10-30 ✅ | Kubescape is an open-source Kubernetes security platform for your IDE, CI/CD pipelines, and clusters. It inclu… |
| OSV-Scanner | 11.3k | 2022 | 2026-10-31 ✅ | Vulnerability scanner written in Go which uses the data provided by https://osv.dev |

*Full inventory — 62 curated tools · ranked by GitHub adoption · 2026-11-06 census · non-GitHub tools listed without stars*

| TOOL | ★ STARS | CREATED | LAST PUSH | LICENSE / TIER |
|---|---|---|---|---|
| Trivy | 38.9k | 2019 | 2026-10-30 ✅ | — the all-in-one scanner: containers, IaC, repos, SBOMs, licenses and secrets, with one binary. Used by DevSecOps teams scanning containers, IaC and repos in CI; the open-source alternative to Snyk and Aqua's commercial scanners. |
| Semgrep | 17.4k | 2019 | 2026-10-30 ✅ | — fast, expressive static analysis with community rule packs for 30+ languages; write rules like you write code. Used by AppSec teams writing custom code-scanning rules fast; the open-source alternative to commercial SAST like Checkmarx and Veracode. (LGPL-2.1) |
| Prowler | 15.1k | 2016 | 2026-11-01 ✅ | — AWS/Azure/GCP security posture: hundreds of checks mapped to CIS benchmarks and compliance frameworks. Used by cloud security teams auditing AWS, GCP and Azure; the open-source alternative to commercial CSPM platforms. |
| Grype | 13.2k | 2020 | 2026-10-30 ✅ | — vulnerability scanner for container images and SBOMs with KEV/EPSS enrichment for prioritization. Used in CI pipelines scanning SBOMs and images for vulnerabilities; the open-source vulnerability scanner from Anchore. |
| Kubescape | 11.8k | 2021 | 2026-10-30 ✅ | — CNCF-incubating Kubernetes security platform: scan manifests, Helm charts, Kustomize dirs, live clusters and images against NSA-CISA, MITRE ATT&CK and CIS frameworks from one CLI. Used by platform teams hardening k8s before and after deploy; CNCF-backed with an in-cluster operator option. (Apache-2.0) |

| | | | | |
|---|---|---|---|---|
| **OSV-Scanner** | 11.3k | 2022 | 2026-10-31 ✅ | — dependency vulnerability scanner backed by Google's OSV database; fast, transparent, no vendor lock. Used by developers scanning dependencies against the OSV database; Google's free alternative to commercial SCA tools. |
| **Clair** | 11.1k | 2015 | 2026-10-30 ✅ | — static vulnerability analysis for container images and registries, from the Quay project. Used by platform teams scanning images in CI/CD pipelines; the veteran open-source container scanner alongside Grype and Trivy. (Apache-2.0) |
| **Syft** | 9.8k | 2020 | 2026-11-01 ✅ | — generate clean SBOMs (SPDX/CycloneDX) from images and filesystems; feeds Grype and everything else. Used by supply-chain teams producing SBOMs in CI; the open-source SBOM generator that Grype and commercial tooling build on. |
| **Docker Bench for Security** | 9.7k | 2015 | 2026-06-04 | — audits your Docker host and daemon configuration against the CIS Benchmark in a single script run. Used by admins auditing Docker hosts against the CIS benchmark; the reference open-source check script. |
| **Falco** | 9.5k | 2016 | 2026-10-30 ✅ | — CNCF runtime threat detection for containers, Kubernetes and cloud workloads. Used by cloud SOC teams detecting runtime threats in Kubernetes; the open-source alternative to commercial CNAPP runtime agents. |
| **Checkov** | 9.1k | 2019 | 2026-10-29 ✅ | — IaC scanning for Terraform, CloudFormation, Kubernetes and more, with auto-fix guidance. Used by DevSecOps scanning Terraform, CloudFormation and Kubernetes for misconfigurations; the open-source IaC scanner alternative to commercial policy platforms. |
| **Bandit** | 8.4k | 2018 | 2026-10-27 ✅ | — the standard Python security linter; wire it into CI and never merge an `eval()` again. Used by Python teams catching security issues in CI; the standard open-source Python SAST tool. |
| **Kyverno** | 8.3k | 2019 | 2026-11-01 ✅ | — CNCF policy engine for Kubernetes: validate, mutate and generate configurations as code. Used by Kubernetes platform teams enforcing policies natively in-cluster; the CNCF alternative to commercial admission-control products. |
| **kube-bench** | 8.2k | 2017 | 2026-10-26 ✅ | — run the CIS Kubernetes Benchmark checks against your nodes in minutes. Used by cluster admins running CIS Kubernetes benchmarks; the open-source compliance check for cluster hardening. |
| **ScoutSuite** | 7.9k | 2018 | 2025-09-23 ⏳ | — the classic multi-cloud security auditor with a friendly HTML report — quiet upstream, still the reference. Used by cloud auditors assessing multi-cloud security posture; the open-source alternative to commercial cloud-security audits. (GPL-3.0) |
| **Brakeman** | 7.3k | 2010 | 2026-10-22 ✅ | — static analysis purpose-built for Ruby on Rails; no config, no instrumentation, just findings. Used by Rails teams scanning source for security flaws; the standard open-source Rails SAST tool. |
| **cppcheck** | 6.8k | 2009 | 2026-10-31 ✅ | — static analysis for C/C++: detects bugs and undefined behavior, not just style. Used by C/C++ developers catching defects and undefined behavior; the free static analyzer alongside commercial suites. (GPL-3.0) |
| **cosign** | 6.4k | 2021 | 2026-10-29 ✅ | — Sigstore's keyless container signing and verification; make provenance part of your pipeline. Used by supply-chain automation signing and verifying containers; the Sigstore tool making signed images the default, free. |
| **Tetragon** | 5.2k | 2022 | 2026-11-05 ✅ | — eBPF-based runtime security tool enforcing policy in-kernel with near-zero overhead for Kubernetes workloads. Used by platform and security engineers; a powerful free runtime defense. (Apache-2.0) |
| **Kube-hunter** | 5.1k | 2018 | 2024-03-19 ⏳ | — Penetration testing tool that hunts for weaknesses in Kubernetes clusters by discovering and exploiting misconfigurations. Used by cloud pentesters; a practical free cluster assessment tool. (Apache-2.0) |
| **Dependency-Track** | 4.4k | 2013 | 2026-10-31 ✅ | — SBOM-based continuous component analysis platform with portfolio risk dashboards. Used by supply-chain teams managing SBOMs and vulnerability exposure continuously; the OWASP alternative to commercial SBOM platforms. |
| **retire.js** | 4.2k | 2013 | 2026-10-30 ✅ | — scanner detecting JavaScript libraries with known vulnerabilities, in web pages and Node dependencies. Used by developers and pentesters flagging risky client-side libraries; the long-standing reference scanner for this niche. (Apache-2.0) |
| **CloudSploit** | 3.8k | 2015 | 2026-09-22 ⏳ | — AWS security auditing tool that scans cloud accounts for misconfigurations and risky settings. Used by cloud security engineers; a practical open-source scanner for AWS posture. (GPL-3.0) |
| **KICS** | 2.7k | 2020 | 2026-10-28 ✅ | — 1,000+ security queries across Terraform, Ansible, K8s, Dockerfile and other IaC. Used by platform teams scanning infrastructure-as-code across platforms; the open-source alternative to commercial IaC security products. |

| | | | | |
|---|---|---|---|---|
| cloudsplaining | 2.3k | 2020 | 2026-10-26 ✅ | — maps AWS IAM policies and flags the privilege-escalation paths you never meant to grant. Used by AWS security teams finding over-privileged IAM policies; the open-source alternative to commercial IAM analyzers. |
| Safety | 2.0k | 2016 | 2026-11-05 ✅ | — Python dependency security scanner that checks installed packages against known vulnerability databases. Used by developers and DevSecOps teams; a practical tool for catching vulnerable dependencies in CI. (MIT) |
| Copacetic | 1.7k | 2023 | 2026-10-26 ✅ | — CLI that patches container images directly from vulnerability scan reports, without rebuilding the Dockerfile. Used by platform teams cutting fix latency on deployed images; a focused open-source image-patching tool. (Apache-2.0) |
| ChipWhisperer | 1.6k | 2014 | 2026-10-30 ✅ | — side-channel analysis and glitching for hardware security research. Used by hardware-security researchers performing side-channel and glitching attacks; the open-source hardware lab that commercial gear costs six figures to replicate. (GPL-3.0) |
| cwe_checker | 1.4k | 2018 | 2026-09-28 | — finds common CWE patterns in binaries, direct from firmware images. Used by firmware auditors mapping binary patterns to CWEs; the open-source binary-analysis aid for embedded reviews. (LGPL-2.1+) |
| Horusec | 1.3k | 2020 | 2026-10-22 ✅ | — open-source SAST orchestration aggregating multiple language analyzers into one report. Used by dev teams running multi-language static analysis in CI; the self-hosted alternative to commercial SAST suites. (Apache-2.0) |
| secureCodeBox | 993 | 2017 | 2026-10-30 ✅ | — Kubernetes-native scanning orchestration: chains nmap, ZAP, Semgrep, SSLyze and more into automated pipelines. Used by DevSecOps teams running declarative scan flows; the open-source continuous-security-testing framework. (Apache-2.0) |
| Substation | 409 | 2022 | 2026-10-28 ✅ | — an event and data pipeline toolkit for detection engineering at scale. Used by OT/ICS security researchers testing industrial protocols; the open-source toolkit for power-grid-class engagements. (MIT) |
| ProgPilot | 371 | 2017 | 2025-08-17 ⏳ | — static taint analysis for PHP sources: finds input-to-sink flows at build time. Used by PHP AppSec teams doing taint analysis of sources and sinks; the open-source PHP static-analysis tool. (GPL-3.0) |
| verifyfetch | 160 | 2026 | 2026-04-07 ⏳ | — Browser-side integrity verification and resumable downloads for large files using SRI hashes, defending against CDN compromise and supply-chain attacks. Used by web developers; a focused supply-chain defense utility. (Apache-2.0) |
| Jacked | 104 | 2023 | 2025-07-07 ⏳ | — Vulnerability scanner for Docker images, code repositories, and tarballs using CycloneDX SBOM internally. Used by DevSecOps teams; a free container scanning utility. (Apache-2.0) |
| NodeAgent | 39 | 2023 | 2026-11-05 ✅ | — Kubescape runtime security agent using eBPF for process monitoring, file integrity, and network tracing. Used by Kubernetes defenders; a free runtime detection component. (Apache-2.0) |
| StackRadar | 4 | 2026 | 2026-11-01 ✅ | — Kubernetes vulnerability scanner that builds an SBOM of every running image and ranks findings by CVSS, EPSS and CISA KEV. Used by DevSecOps teams prioritizing which container CVE actually matters in-cluster; the self-hosted alternative to commercial runtime CSPM. (AGPL-3.0) |
| command-center | 3 | 2025 | 2026-04-17 | — OpenJS security and compliance monitor tracking SECURITY.md hygiene and OSSF Scorecard posture across projects. Used by open-source maintainers monitoring project security posture; the OpenJS supply-chain health monitor. (MIT) |
| GDB | — | — | — | — the GNU debugger: breakpoints, watchpoints and reverse debugging across dozens of architectures. Used by reverse engineers and exploit developers on every platform; the GNU debugger standard for binary analysis. (GPL-3.0) |
| WinDbg | — | — | — | — the Windows debugger for user, kernel and crash-dump analysis; now with a modern UI. Used by malware analysts and driver developers debugging Windows; Microsoft's debugger at the core of Windows-forensics work. (free, proprietary) |
| Slither | 6401 | 2018 | 2026-10-29 ✅ | — Solidity static analysis, 90+ detectors. (AGPL-3.0) |
| AFL++ | 6842 | 2019 | 2026-10-30 ✅ | — coverage-guided fuzzer, the community fork that won. (AGPL-3.0) |
| pip-audit | 1389 | 2021 | 2026-10-30 ✅ | — Python dependency vulnerability scanning (PyPA). (Apache-2.0) |
| xeol | 450 | 2022 | 2026-10-06 ✅ | — end-of-life dependency detection. (Apache-2.0) |
| CodeQL | 10286 | 2018 | 2026-10-30 ✅ | — semantic code analysis, free for research. (MIT) |

github.com/[illegible]/awesome-[illegible]-heaven · CC0 [illegible]

| | | | | |
|---|---|---|---|---|
| cloudfox | 2615 | 2022 | 2026-10-31 ✅ | — cloud attack-surface auditor (AWS/Azure/GCP). (MIT) |
| GCP Scanner | 372 | 2022 | 2025-12-05 | — GCP security scanner from google. (Apache-2.0) |
| Tracee | 4663 | 2019 | 2026-11-01 ✅ | — eBPF container runtime security tracing. (Apache-2.0) |
| Open Policy Agent (OPA) | — | — | — | — Policy engine applying unified rules across microservices, Kubernetes, CI/CD, and API gateways. Used by platform and security teams; a widely adopted free policy framework. |
| Calico | — | — | — | — Open-source networking and network policy engine for containers operating at layer three. Used by Kubernetes operators; a mature free network security solution. |
| Istio | — | — | — | — Open-source service mesh for Kubernetes providing traffic control, security, monitoring, and policy enforcement via sidecar proxies. Used by platform engineers; a leading free mesh. |
| Kimera | — | — | — | — Kubernetes security validation platform from Dynatrace testing whether controls actually block attacks. Used by Kubernetes defenders; a free attack-validation tool. |
| SLSA (Supply-chain Levels for Soft… | — | — | — | — OpenSSF security framework providing standards and controls to prevent supply chain tampering. Used by software producers and consumers; a widely adopted free framework. |
| Sigstore | — | — | — | — Open-source project for signing and verifying software artifacts to improve supply chain security. Used by developers and release engineers; a foundational free signing ecosystem. |
| in-toto | — | — | — | — CNCF-graduated framework protecting software supply chain integrity by verifying each task in the chain. Used by build and release teams; a mature free attestation framework. |
| CycloneDX | — | — | — | — OWASP-led SBOM standard lightweight and suited for expressing component relationships and vulnerabilities. Used by developers and security teams; a widely adopted free standard. |
| SPDX | — | — | — | — Linux Foundation SBOM standard emphasizing license compliance expression. Used by compliance and security teams; a popular free regulatory-friendly standard. |
| Chainloop | — | — | — | — Open-source evidence store for supply chain attestations, SBOMs, VEX, SARIF, and QA reports with SLSA Level 3 support. Used by DevSecOps teams; a capable free attestation platform. |
| OpenSSF Scorecard | — | — | — | — Automated tool assessing repositories against security heuristics and assigning scores. Used by open-source maintainers and consumers; a free supply chain risk signal. |
| GardWatch | — | — | — | — CLI tool analyzing dependencies for trust, security risks, and quality signals across PyPI, npm, Go, Cargo, Maven, and NuGet. Used by developers; a free dependency risk checker. |
| Chainmail | — | — | — | — Unified open-source workbench bringing eight supply chain security capabilities together in one place. Used by DevSecOps teams; a free consolidated supply chain toolkit. |
| Chef InSpec | — | — | — | — Open-source testing framework for infrastructure compliance with an auditd resource for testing audit rules against system configuration. Used by DevSecOps engineers; compliance-as-code for infrastructure. (Apache-2.0) |